

**TLP:CLEAR****BEC via Compromised NGO Mailbox + Tycoon 2FA AiTM Kit**

Thread hijacking, Microsoft Customer Voice abuse, and multi-layer AiTM phishing infrastructure

BEC | Thread Hijacking | AiTM | Tycoon 2FA | Microsoft 365 | PaaS Phishing

| Parameter      | Value                                                        |
|----------------|--------------------------------------------------------------|
| Incident date  | May 11, 2026, 21:22 UTC                                      |
| Analysis date  | May 12, 2026                                                 |
| Classification | TLP:CLEAR                                                    |
| Threat level   | HIGH                                                         |
| Type           | BEC / Thread Hijacking / AiTM Phishing / PaaS Phishing Kit   |
| Email subject  | FW: ACH Submission Attached                                  |
| Sender domain  | unapei-ap.fr (compromised M365 mailbox)                      |
| Target domain  | zenpulsar.com (financial mailbox, Google Workspace)          |
| Lure URL       | hxxps://nam[.]dvc[.]ms/o9XDteis3W (Microsoft Customer Voice) |
| Final stage IP | 198[.]23[.]210[.]61 (RackNerd / ColoCrossing, US)            |
| Kit family     | Tycoon 2FA / Mamba 2FA (Storm-1575)                          |

**1. Executive Summary**

On May 11, 2026 a high-confidence BEC (Business Email Compromise) phishing email was delivered from a legitimate Microsoft 365 mailbox belonging to a French non-profit organisation, UNAPEI Alpes Provence. The mail traversed genuine Microsoft Exchange Online outbound infrastructure — this is account compromise, not domain spoofing.

The attack uses three evasion layers. First, the sender account is real and the email is transmitted through authentic M365 servers, bypassing SPF/DKIM/DMARC checks. Second, the email hijacks a real internal conversation thread in French — an orthopaedic medical exchange — to look contextually legitimate to anti-phishing filters. Third, the single link in the email resolves through a legitimate Microsoft service (Customer Voice / Forms Pro, nam.dvc.ms), which is on the allow-list of most enterprise gateways.

The ultimate destination is a Tycoon 2FA / Mamba 2FA class Phishing-as-a-Service (PaaS) kit hosted on a RackNerd VPS in the United States. The kit presents a fake Gmail/Google sign-in flow, filters out bots and sandbox crawlers via an XOR-obfuscated API check, and harvests credentials and session cookies to bypass MFA. At least seven parallel phishing domains were identified operating from the same infrastructure cluster, all provisioned on April 17, 2026.

**2. Attack Timeline**

| Date/Time (UTC)     | Event                                                                                                                                                              |
|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2018-06-25          | Domain unapei-ap.fr registered (legitimate). Owner: UNAPEI Alpes Provence, France.                                                                                 |
| 2026-04-17          | Let's Encrypt certificates provisioned for all 7 phishing domains in the cluster (stiofidri.company and 6 parallels) — 3–4 weeks before the attack.                |
| 2026-05-11 14:50:51 | Microsoft Customer Voice form created using a compromised M365 account in the unapei-ap.fr tenant. Title: «A SECURED FILED HAS BEEN SUCCESSFULLY SHARED WITH YOU!» |
| 2026-05-11 14:54:26 | Form finalised; payload link set to <code>hxxps://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/</code>                                                              |
| 2026-05-11 ≤21:22   | M365 mailbox at unapei-ap.fr compromised (vector: likely prior AiTM cycle).                                                                                        |
| 2026-05-11 21:22:03 | Phishing email sent via DB9PR08MB6809.eurprd08.prod.outlook.com to a financial mailbox at zenpulsar.com.                                                           |
| 2026-05-12 09:05    | HybridAnalysis auto-scan of the URL captured the Microsoft Forms landing via URLscan.                                                                              |
| 2026-05-12 ~13:00   | Investigation initiated. <code>nam.dcv.ms/o9XDteis3W</code> returns HTTP 404 — form deleted. All phishing domains still live.                                      |

### 3. The Lure Email

#### 3.1. Headers and authentication

The email transited the legitimate Microsoft 365 outbound path (DB9PR08MB6809.eurprd08 → GV1PR08MB8132 → AM0PR83CU005.outbound → mail-west europeazlp170100001, IPv6 2a01:111:f403:c201::1). This routing is identical to a genuine M365 send from the UNAPEI EU tenant. The Message-ID format (DB9PR08MB680983CEE2CDAC9D35F40C23BC382@DB9PR08MB6809...) is issued exclusively by Exchange Online for real account sends.

- SPF: domain unapei-ap.fr has a valid record (includes `spf.protection.outlook.com ~all`) — the auth result «none» at the Google MX reflects an edge case in the delivery path, not a spoof.
- DKIM: none at Google MX — the Microsoft-to-Google hop did not carry a valid DKIM signature for unapei-ap.fr, consistent with a misconfiguration in UNAPEI's DNS rather than spoofing.
- DMARC: `v=DMARC1; p=none` — policy is advisory only. No enforcement, no quarantine.

All evidence confirms this is account compromise (ATO), not spoofing.

#### 3.2. Thread hijacking and social engineering

The attacker extracted a genuine conversation from the compromised mailbox: a French-language exchange between healthcare professionals at UNAPEI, dated March 2026, discussing a patient's care plan. This thread is embedded verbatim below the phishing text

— a deliberate technique to create contextual legitimacy and to include benign keywords that confuse content classifiers.

- The phishing body is in English; the hijacked thread is in French — a language mismatch that a trained user would notice.
- Forged signature claims the role of «Chief Financial Officer (CFO), Unapei Alpes Provence» — the real account holder is a healthcare professional, not a CFO. The role elevation is intended to justify a financial ACH request.
- Financial lure: «Please find attached the ACH submission related to the completed balance settlement... REVIEW CONFIRMATION AND STATEMENT» — typical BEC / wire transfer fraud script.

4. Stage 1 — Microsoft Customer Voice Abuse (nam.dcv.ms)

The single link in the email body — «REVIEW CONFIRMATION AND STATEMENT» — resolves through nam.dcv.ms/o9XDteis3W, a legitimate Microsoft URL shortener for the Customer Voice (Forms Pro) product. This domain is CNAME-chained to msformspro.azurefd.net (Azure Front Door CDN) and is on the allow-list of virtually every enterprise URL filtering solution.

| Parameter               | Value                                                                        |
|-------------------------|------------------------------------------------------------------------------|
| Short URL               | hxxps://nam[.]dcv[.]ms/o9XDteis3W                                            |
| Resolved to             | hxxps://customervoice[.]microsoft[.]com/Pages/ResponsePage.aspx?id=gKJ6Dz... |
| Form title              | «A SECURED FILED HAS BEEN SUCCESSFULLY SHARED WITH YOU!»                     |
| Compromised M365 tenant | unapei-ap.fr (ID available to MSRC upon request)                             |
| Form created            | 2026-05-11 14:50:51 UTC                                                      |
| Form modified           | 2026-05-11 14:54:26 UTC                                                      |
| Status at analysis      | HTTP 404 — deleted by Microsoft or attacker                                  |

The form's visible question text was «Dated: Fri, May 2026», and the only CTA was «CLICK HERE TO FULL REPORTS», linking to hxxps://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/.

URLscan data shows this Customer Voice abuse pattern has been running since at least May 2025, with more than 100 scans of nam.dcv.ms short-links across multiple languages (English, German, Spanish, Indonesian) and themes: «New PDF Document Received», «Payment Advice Note», «Electronic Funds Transfer Notification». This is a long-running, multi-lingual, globally-targeted campaign.

5. Stage 2 — Tycoon 2FA AiTM Phishing Kit

5.1. Infrastructure

| Parameter   | Value               |
|-------------|---------------------|
| Host domain | stiofidri[.]company |

|            |                                                               |
|------------|---------------------------------------------------------------|
| IP         | 198[.]23[.]210[.]61                                           |
| ASN        | AS36352 — ColoCrossing / RackNerd LLC, Chicago, IL, US        |
| TLS cert   | Let's Encrypt R13, issued 2026-04-17, valid until 2026-07-16  |
| CDN        | Cloudflare (CF-RAY 9fa9e25929336872-NRT)                      |
| Web server | Nginx 1.18.0 on Ubuntu                                        |
| Backend    | Laravel (cookies: XSRF-TOKEN, laravel_session, samesite=none) |
| NS         | a.dnspod.com / b.dnspod.com / c.dnspod.com (Tencent DNSPod)   |

5.2. Anti-analysis layers

The kit employs two distinct anti-analysis mechanisms before showing its payload:

- CAPTCHA gate: a fake «Human Check / Verify identity» UI styled as Gmail. The user must enter a dynamically generated 5-character code. This blocks automated scanners that cannot solve CAPTCHAs.
- Sandbox/cloud-IP filter: upon correct CAPTCHA entry, the kit calls api.ipapi.is to verify the visitor's ASN. If the ASN matches any hosting provider (AWS, Google, Microsoft, Cloudflare, OVH, Hetzner, DigitalOcean, Linode, Akamai, Fastly, AS13335, Leaseweb, M247, LSN), the browser is silently redirected to www.meituan.com (a neutral Chinese platform). The filter logic is XOR-obfuscated (key: 3HO3y7Soso1HgJPsnDn2pg==, base64) and the block-list strings are stored reversed.

5.3. Credential harvesting stage (AiTM)

Visitors passing both filters see an «Verifying your session... Validating email address...» transition screen. This is the hallmark of an Adversary-in-the-Middle (AiTM) kit: the backend simultaneously performs real authentication requests against the victim's identity provider (Google Workspace or Microsoft 365), passing the user's credentials and obtaining session cookies that are valid even after MFA completion. The harvested cookies allow the attacker to take over the authenticated session without knowing or needing to bypass MFA.

5.4. Infrastructure cluster

All seven phishing domains share identical DNS infrastructure (DNSPod NS), the same hosting IP (198.23.210.61), and Let's Encrypt certificates issued on the same date (April 17, 2026). This is a single PaaS operator provisioning multiple domains for parallel campaigns or to rotate when individual domains are burned.

| Domain              | Cert issued | NS               |
|---------------------|-------------|------------------|
| stiofidri[.]company | 2026-04-17  | a/b/c.dnspod.com |
| giochogio[.]company | 2026-04-17  | a/b/c.dnspod.com |
| crepeawi[.]business | 2026-04-17  | a/b/c.dnspod.com |
| crivesha[.]company  | 2026-04-17  | a/b/c.dnspod.com |

|                          |            |                  |
|--------------------------|------------|------------------|
| driocriodio[.]app        | 2026-04-17 | a/b/c.dnspod.com |
| beawoushoo[.]digital     | 2026-04-17 | a/b/c.dnspod.com |
| shodiothai[.]enterprises | 2026-04-17 | a/b/c.dnspod.com |

6. Indicators of Compromise (IOC)

6.1. Network — Malicious (block)

| Type   | Value                                                | Notes                                                    |
|--------|------------------------------------------------------|----------------------------------------------------------|
| IP     | 198[.]23[.]210[.]61                                  | RackNerd/Cc<br>AS36352 —<br>phishing VP;<br>domains host |
| Domain | stiofidri[.]company                                  | Phishing kit I<br>block                                  |
| Domain | giochogio[.]company                                  | Cluster — bl                                             |
| Domain | crepeawi[.]business                                  | Cluster — bl                                             |
| Domain | crivesha[.]company                                   | Cluster — bl                                             |
| Domain | driocriodio[.]app                                    | Cluster — bl                                             |
| Domain | beawoushoo[.]digital                                 | Cluster — bl                                             |
| Domain | shodiothai[.]enterprises                             | Cluster — bl                                             |
| URL    | hxxps://stiofidri[.]company/u@xTBw1Q9qK4Qb0ZS9gxFUS/ | Specific payl<br>(this campaig                           |

6.2. Network — Compromised (notify, do not block)

| Type   | Value                             | Notes                                                                                                |
|--------|-----------------------------------|------------------------------------------------------------------------------------------------------|
| Domain | unapei-ap[.]fr                    | Legitimate French<br>NGO — mailbox<br>compromised, notify<br>organisation IT, do not<br>block domain |
| URL    | hxxps://nam[.]dcv[.]ms/o9XDteis3W | Microsoft Customer<br>Voice short-link (form<br>now 404) — alert, do<br>not block domain-wide        |

6.3. Phishing Kit Fingerprints

| Indicator             | Value                                                   |
|-----------------------|---------------------------------------------------------|
| XOR key (base64)      | 3HO3y7Soso1HgJPsnDn2pg==                                |
| Sandbox detection API | api[.]lipapi[.]is                                       |
| Decoy redirect        | www[.]meituan[.]com                                     |
| URL path pattern      | /u@<random-token>/                                      |
| Backend fingerprint   | Laravel (XSRF-TOKEN, laravel_session;<br>samesite=none) |

|                       |                                                         |
|-----------------------|---------------------------------------------------------|
| Page title (mid-flow) | «Verifying your session... Validating email address...» |
| CAPTCHA style         | Fake Gmail / Google identity check                      |
| Typo in form title    | «FILED» instead of «FILE» — operator's recurring typo   |

## 7. MITRE ATT&CK

| ID        | Technique                                     | Observed                                                                |
|-----------|-----------------------------------------------|-------------------------------------------------------------------------|
| T1583.001 | Acquire Infrastructure: Domains               | 7 disposable domains registered ~3 weeks before attack                  |
| T1583.004 | Acquire Infrastructure: Server                | RackNerd VPS<br>198.23.210.61 as PaaS front                             |
| T1586.002 | Compromise Accounts: Email Accounts           | M365 ATO of a mailbox at unapei-ap.fr                                   |
| T1078.004 | Valid Accounts: Cloud Accounts                | Genuine M365 account used to send email and create Customer Voice forms |
| T1566.002 | Phishing: Spearphishing Link                  | Targeted email with embedded URL to financial mailbox at zenpulsar.com  |
| T1566.003 | Phishing: Spearphishing via Service           | Microsoft Customer Voice (nam.dcv.ms) as trusted intermediary           |
| T1656     | Impersonation                                 | Account holder falsely presented as «CFO» to justify financial request  |
| T1036.005 | Masquerading: Match Legitimate Name           | nam.dcv.ms / Microsoft Forms used to evade URL filtering                |
| T1027.013 | Obfuscated Files: Encrypted/Encoded File      | XOR-obfuscated JS with base64 key in phishing kit                       |
| T1497.001 | Virtualization/Sandbox Evasion: System Checks | api.ipapi.is cloud-IP check before payload reveal                       |
| T1480     | Execution Guardrails                          | CAPTCHA gate before second stage                                        |
| T1539     | Steal Web Session Cookie                      | AiTM kit harvests session cookies to bypass MFA                         |
| T1056.003 | Input Capture: Web Portal Capture             | Fake Gmail sign-in credential harvesting                                |
| T1114.002 | Email Collection: Remote Email Collection     | Real thread extracted from victim mailbox for context injection         |

## 8. Recommendations

### 8.1. Immediate — for UNAPEI Alpes Provence

- Reset credentials and revoke all refresh/access tokens for the compromised mailbox via Entra ID.
- Audit Entra ID sign-in logs for the period 2026-04 to 2026-05: look for geographic anomalies, successful MFA pass-through, or new app passwords / OAuth grants.
- Check inbox rules for the affected mailbox — attacker may have created forwarding rules or rules to delete security notifications.
- Raise DMARC policy of unapei-ap.fr from p=none to p=quarantine (short-term) then p=reject (long-term).
- Report the compromised account to Microsoft MSRC (msrc.microsoft.com/report/abuse) to trigger internal account lockout. Tenant and user identifiers are available to MSRC upon request.

### 8.2. Immediate — for infrastructure takedown

- Report all 7 phishing domains to Identity Digital (TLD operator for .company, .business, .digital, .app, .enterprises): abuse@identity.digital
- Report IP 198.23.210.61 to RackNerd abuse: abuse@racknerd.com
- Report to Cloudflare abuse (cloudflare.com/abuse/form) — Cloudflare is the CDN for all domains.
- Report to DNSPod (Tencent): abuse@dnspod.cn — to revoke DNS delegation for all 7 domains.

### 8.3. Defensive controls for email gateways

- Block the 7 malicious domains and IP 198.23.210.61 in DNS RPZ, web proxy, and email gateway.
- Do NOT block nam.dcv.ms or customervoice.microsoft.com globally — create an alert rule instead: inbound email from external senders containing nam.dcv.ms/\* with financial subjects (ACH, Payment, Statement, Wire, EFT, Invoice) → quarantine for review.
- Create a YARA/Sigma rule for the anti-analysis JS pattern: XOR-encoded fetch to api.ipapi.is with reversed-string cloud-IP block-list — high-confidence signature for this kit family.
- Flag the typo «FILED» (instead of «FILE») as a subject and content keyword in phishing rules — this operator consistently makes this error.
- In Entra ID: restrict Customer Voice form creation to authorised marketing groups to reduce risk if your own M365 tenant is compromised.

### 8.4. User awareness

- Train users to recognise role-mismatch social engineering: an email from a known contact with an unusual role (e.g. healthcare professional signing as CFO) is a red flag.
- Clarify that Microsoft Forms / Customer Voice links are not a legitimate delivery mechanism for financial documents — any email directing to [customervoice.microsoft.com](https://customervoice.microsoft.com) for an ACH or payment should be treated as suspect.
- Teach the bilingual thread pattern: if the quoted thread is in a different language than the top message, this is a strong indicator of thread hijacking.

**TLP:CLEAR — This document may be distributed without restriction.**